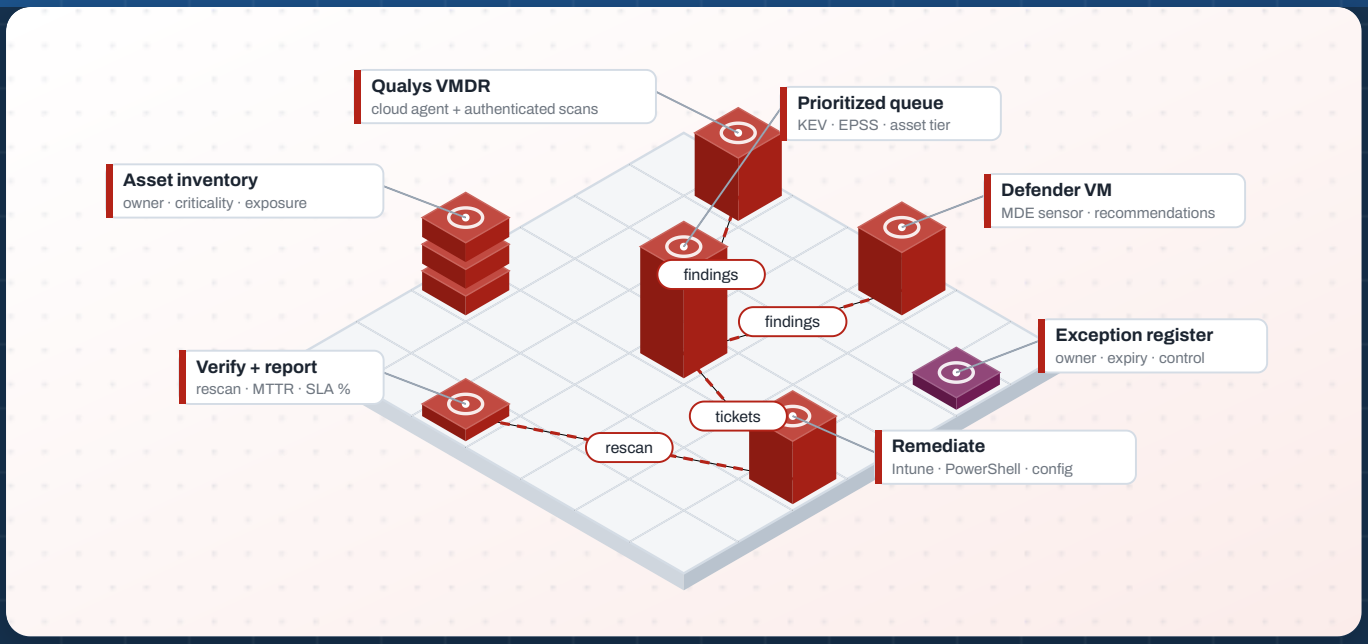
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-SEC-001

# Running a Vulnerability Remediation Program with Qualys and Microsoft Defender

Discover, assess, prioritize, remediate, verify and report: two scanners reconciled into one queue, priorities set by exploitation rather than CVSS alone, SLAs by risk tier, scripted patch deployment and verification, and a dated exception process that auditors can follow.

Security Operations | Vulnerability Management | Patch Management




| | |
|---|---|
| DOCUMENT ID | SOP-SEC-001 |
| VERSION | 1.0 |
| EFFECTIVE | October 2026 |
| AUDIENCE | Security engineers, endpoint and server administrators, asset owners, risk and audit (Chapter 7) |
| AUTHOR | Richmond Dieujuste, Principal Consultant |

# Contents

**1. Concepts You Need First** 3
1.1 The remediation lifecycle 3
1.2 Asset inventory and ownership 4
1.3 Two scanners, one queue 5
1.4 Severity is not priority 6

**2. Access, Prerequisites and Planning** 8
2.1 Level of access required 8
2.2 Prerequisites checklist 8
2.3 Risk and planning notes 9
2.4 Scope exclusions 9

**3. Prioritization and Remediation SLAs** 10
3.1 Example remediation SLA policy 10
3.2 Remediation types 11

**4. Method A · Working the Queue in the Consoles** 12
4.1 Qualys VMDR 12
4.2 Microsoft Defender Vulnerability Management 12
4.3 Ticketing: one action, one ticket 13

**5. Method B · Hunting, Automation and Verification** 14
5.1 Advanced hunting queries 14
5.2 Deploying fixes 14
5.3 Linux servers 15
5.4 Verification and closure 16

**6. Exceptions, Metrics and Reporting** 17
6.1 Exception (risk acceptance) workflow 17
6.2 Metrics that matter 18
6.3 Reporting cadence 18

**7. Verification, Rollback and Troubleshooting** 20
7.1 Program health checklist 20
7.2 Rollback 20
7.3 Troubleshooting 21

**8. Summary, Glossary and Review** 22
8.1 Chapter summary 22
8.2 Glossary 22
8.3 Framework references 23

**LEARNING OBJECTIVES**

*After working through this procedure you will be able to:*

- Describe the six-stage remediation lifecycle and who owns each stage.
- Explain how Qualys VMDR and Microsoft Defender Vulnerability Management collect findings, and reconcile the two into one queue.
- Prioritize findings with CISA KEV, EPSS, exploit availability, asset criticality and exposure, not CVSS alone.
- Remediate at scale with Intune and PowerShell, verify by rescan, and close findings with evidence.
- Run a time-boxed exception (risk acceptance) process and report MTTR, SLA compliance and burn-down.

| Time | Difficulty | Minimum access | Risk |
|---|---|---|---|
| Initial build 1–2 weeks · then a weekly cycle | Intermediate | Scanner analyst + endpoint admin (Intune) | Moderate: patches and reboots touch production |

CHAPTER 1

# Concepts You Need First

A vulnerability program is not a scanner. Scanners produce findings; a **program** turns findings into fixed systems on a predictable schedule, with a named owner for every asset and a written decision for every finding that is not fixed. The measure of success is not how many findings were reported but how quickly the ones that matter were closed.

**KEY CONCEPT · A QUEUE, NOT A REPORT**

Treat the output of the scanners as a work queue with service levels, the same way a service desk treats tickets. A 400-page scan report is evidence that scanning happened; a queue sorted by real-world risk, with owners and due dates, is what gets systems patched.

## 1.1 The remediation lifecycle

Every finding moves through the same six stages. Each stage has an owner and an exit condition, and the cycle repeats weekly: new scan data arrives, priorities are recalculated, and closed findings are confirmed by the next scan rather than by a ticket being marked done.

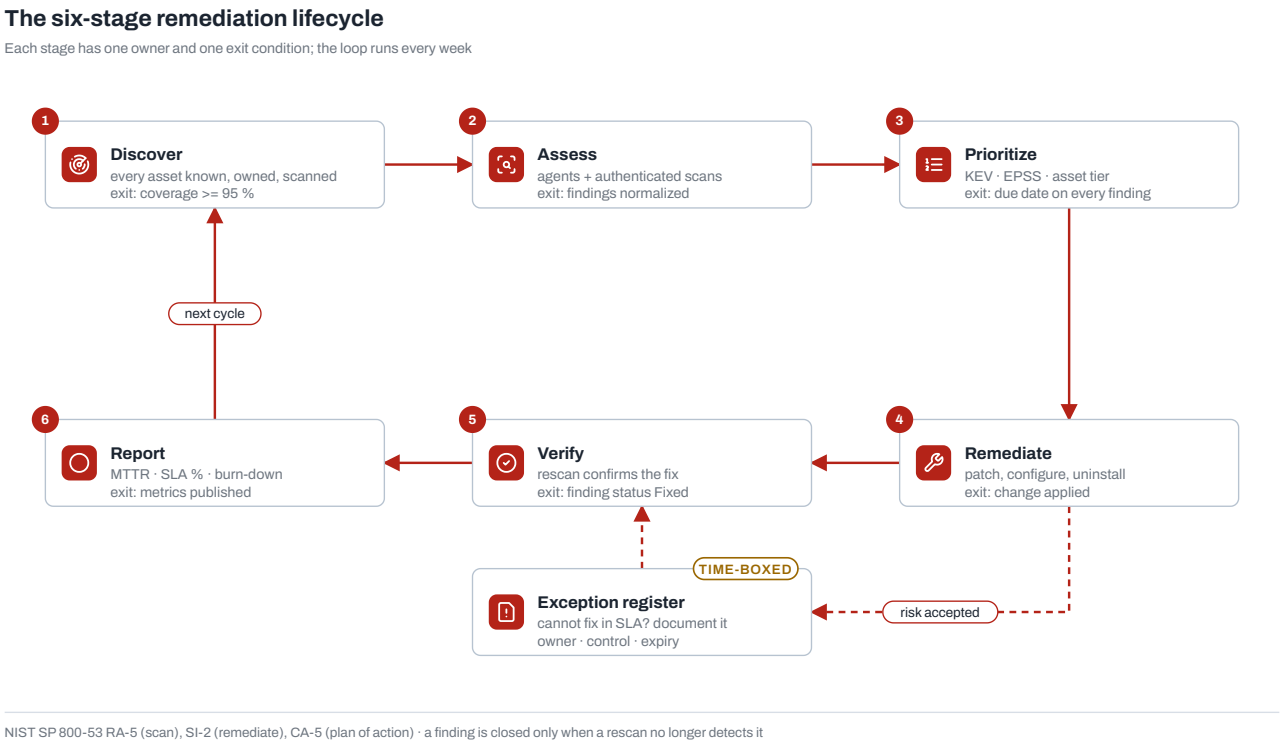



**Figure 1.** The lifecycle. A finding leaves the loop only when a rescan confirms it is fixed or when a dated exception is approved.

| Stage | Owner | Key output |
|---|---|---|
| **Discover** | Vulnerability management lead with IT asset management | Asset inventory with owner, criticality tier, internet exposure, scan coverage |
| **Assess** | Vulnerability analyst | Normalized findings from both scanners, duplicates merged |
| **Prioritize** | Vulnerability analyst | Risk tier and due date on every open finding |
| **Remediate** | Asset owner (endpoint, server, application teams) | Patch, configuration change or removal, applied through change control |
| **Verify** | Vulnerability analyst | Rescan result; finding moves to *Fixed* or reopens |
| **Report** | Vulnerability management lead | Weekly operational metrics, monthly risk report, exception register |

## 1.2 Asset inventory and ownership

You cannot remediate what you do not know you own. Before a single finding is prioritized, every scanned asset needs three attributes: an **owner** (a team, not a person who might leave), a **criticality tier**, and an **exposure** flag. Without an owner a finding has nowhere to go; without a tier every critical CVE looks equally urgent.

| Tier | Definition | Examples |
|---|---|---|
| **Tier 0** | Controls identity or the security stack; compromise means compromise of everything | Domain controllers, Entra Connect servers, PAM vault, EDR and scanner consoles |
| **Tier 1** | Business-critical or regulated data; internet-facing services | ERP and quality systems, file servers with regulated data, VPN gateways, web front ends |
| **Tier 2** | Standard servers and infrastructure | Print servers, internal application servers, build agents |
| **Tier 3** | End-user devices | Windows and macOS laptops and desktops, shared kiosks |

> **GOOD PRACTICE · TAG IN BOTH TOOLS, FROM ONE SOURCE**
>
> Keep tier, owner and exposure in the CMDB and push them into Qualys as **asset tags** and into Defender as **device tags** and **device value** (Low / Normal / High). Prioritization and reporting then work the same way in both consoles.

## 1.3 Two scanners, one queue

This SOP assumes two sources. **Qualys VMDR** covers servers, network devices, Linux and anything the EDR does not run on, using the Qualys **Cloud Agent** and **authenticated network scans**. **Microsoft Defender Vulnerability Management** (MDVM) covers every device onboarded to Defender for Endpoint, using the sensor already installed, with no separate scan. The two overlap on Windows endpoints and servers; they disagree occasionally, and that is useful.

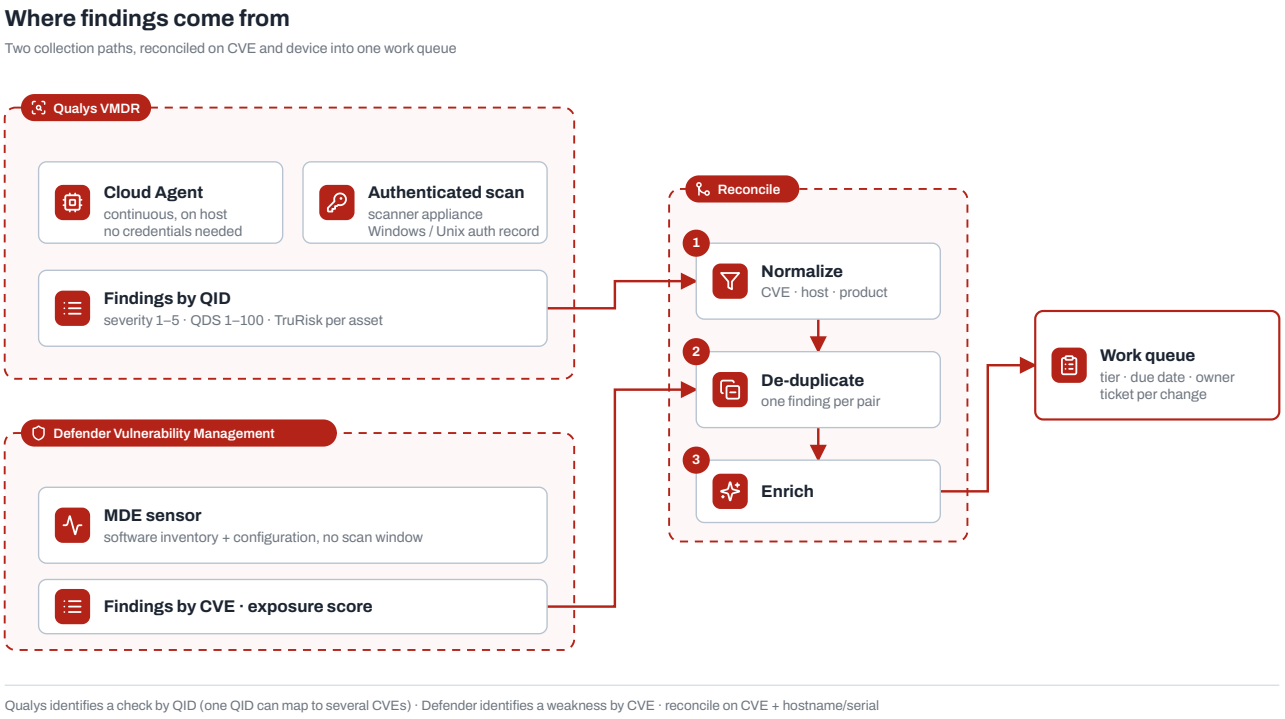



**Figure 2.** Qualys and Defender feed one queue. The overlap on Windows devices is reconciled rather than double-counted.

## 1.4 Severity is not priority

CVSS describes how bad a vulnerability *could* be in the abstract. Fewer than one in twenty published CVEs is ever seen exploited, so a queue sorted by CVSS alone spends most of its effort on findings no attacker will use. Priority combines the vulnerability with what is known about exploitation and with the asset it sits on.

| Signal | What it tells you | Where to find it |
|---|---|---|
| **CVSS base score** | Technical severity if exploited | Both scanners; NVD |
| **CISA KEV** | Exploitation **confirmed** in the wild; US federal agencies must remediate by the KEV due date (BOD 22-01) | Qualys threat-intel filter; Defender *Exploit verified* / threat insights; cisa.gov KEV catalog |
| **EPSS** | Probability (0–1) of exploitation activity in the next 30 days | FIRST.org EPSS; Qualys and Defender surface exploit prediction |
| **Exploit available** | Public exploit code or an exploit kit exists | Defender `IsExploitAvailable`; Qualys threat indicators |
| **Qualys QDS / TruRisk** | Vendor risk score combining CVSS, exploitation and malware association (QDS) and asset criticality (TruRisk) | Qualys VMDR |

| Signal | What it tells you | Where to find it |
| --- | --- | --- |
| **Asset tier and exposure** | How much damage, and how reachable | CMDB; Qualys asset criticality (ACS); Defender device value and internet-facing flag |

CHAPTER 2

# Access, Prerequisites and Planning

## 2.1 Level of access required

| Task | Minimum access | Notes |
|---|---|---|
| **View findings, dashboards, reports in Qualys** | Qualys *Reader* role scoped to asset groups | Asset owners get read access to their own tags. |
| **Configure scans, authentication records, tags** | Qualys *Scanner* or *Manager* role | Store scan credentials in a vault integration where available. |
| **View MDVM dashboards, recommendations, inventories** | Defender RBAC: *Security operations* › *Security data basics (read)* and *Vulnerability management (read)* | Unified RBAC in the Defender portal. |
| **Request remediation, create exceptions in MDVM** | *Vulnerability management - remediation handling* and *exception handling* | Exceptions need a second approver per this SOP. |
| **Deploy updates and apps** | Intune Administrator or a custom Intune role (*Device configurations*, *Mobile apps*) | Through change control (SOP-GOV-001). |
| **Run advanced hunting** | Defender *Security data basics (read)* | Read-only; safe for analysts. |

## 2.2 Prerequisites checklist

- ☐ Asset inventory exported from the CMDB with owner, tier and exposure; reconciled against Qualys and Defender device lists.
- ☐ Qualys Cloud Agent deployed to servers and endpoints in scope (SOP-EP-001 covers agent rollout patterns); activation key and configuration profile documented.
- ☐ Authentication records created for network scans of devices without an agent (Windows domain account with local admin via GPO; Unix account with sudo for the scanner).
- ☐ Defender for Endpoint onboarded on every Windows, macOS and Linux device in scope; legacy antivirus removed (SOP-EP-002).
- ☐ Intune connected to Defender for Endpoint (*Endpoints* › *Settings* › *Advanced features* › *Microsoft Intune connection*) so remediation requests become Intune security tasks.
- ☐ Windows update rings and feature/quality update policies in place (SOP-EM-005).
- ☐ Remediation SLA policy approved by the risk owner (Chapter 3).
- ☐ Ticketing queue and change templates for standard patching and emergency changes.

## 2.3 Risk and planning notes

| Action | Risk | Notes |
|---|---|---|
| **Read findings, run reports and hunting queries** | READ-ONLY | Always first. |
| **Deploy Cloud Agent** | LOW | Small footprint; pilot on each OS build before broad rollout. |
| **Authenticated network scan of production** | MODERATE | Schedule outside business hours; exclude fragile OT and lab instruments. |
| **Monthly quality updates to endpoints via rings** | LOW | Standard change; pilot ring first. |
| **Patch Tier 0 / Tier 1 servers** | MODERATE | Maintenance window, snapshot or backup, owner sign-off. |
| **Uninstall vulnerable software at scale** | MODERATE | Confirm business use with owners; a removal can break a workflow. |
| **Emergency patch for an actively exploited KEV** | HIGH | Emergency change; compressed testing; rollback plan mandatory. |

## 2.4 Scope exclusions

Some systems cannot be patched on the normal cycle: validated laboratory instruments, medical and OT devices, vendor-managed appliances. They are **not** excluded from scanning. They are scanned (often with agent-less, low-intensity profiles), their findings are tracked, and remediation is handled through the exception process with compensating controls such as network segmentation. Validated systems also need change control under the quality system before any patch (SOP-GOV-001).

CHAPTER 3

# Prioritization and Remediation SLAs

Priority is assigned once per finding, automatically where possible, and drives the due date. The tiers below are an example policy; adopt them through your risk owner and record the approved version in the program charter.

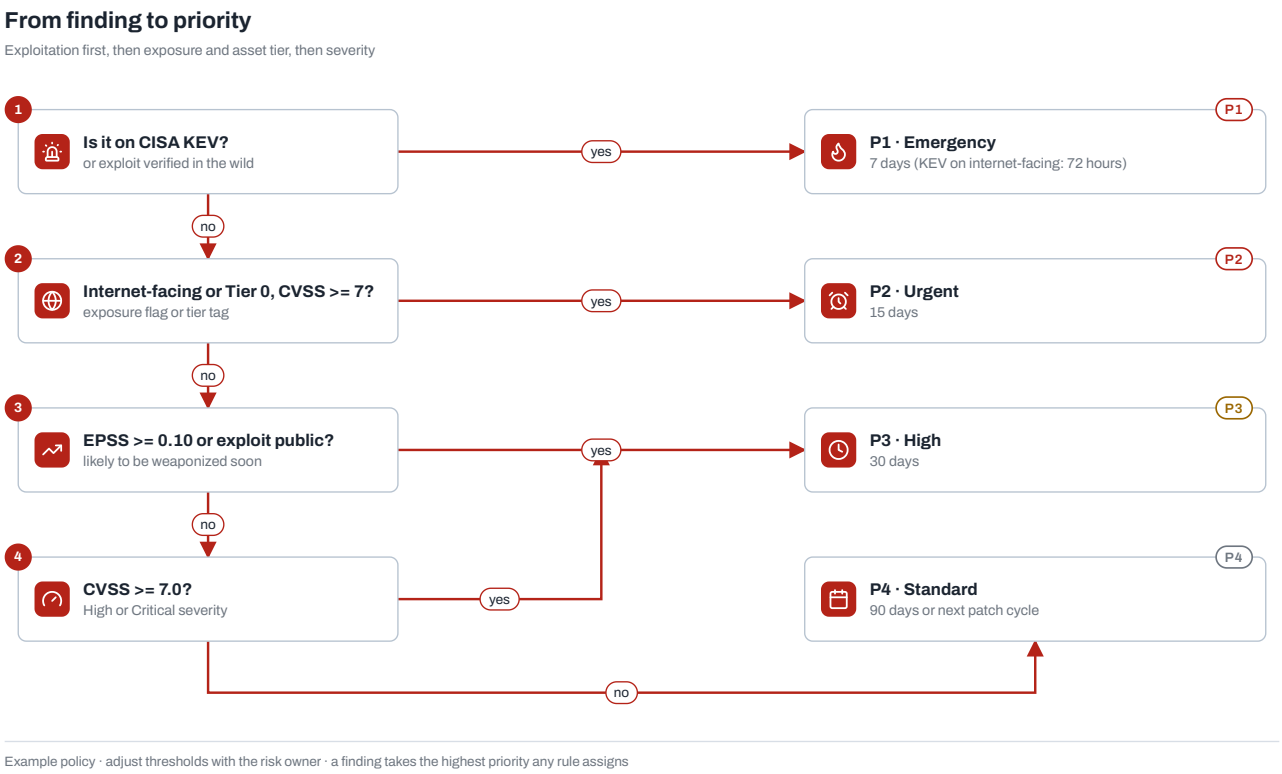



**Figure 3.** Example decision path. KEV and active exploitation override severity; exposure and tier raise priority; CVSS is the last test, not the first.

## 3.1 Example remediation SLA policy

| Priority | Criteria (any) | Due | Escalation if missed |
|---|---|---|---|
| **P1 Emergency** | On CISA KEV; vendor or threat intel reports active exploitation; Defender *Exploit verified* | 7 days · 72 h if internet-facing | CISO same day; emergency change |
| **P2 Urgent** | CVSS >= 7 on internet-facing or Tier 0 asset; EPSS >= 0.10 on Tier 0/1 | 15 days | Head of IT operations |
| **P3 High** | CVSS >= 7 elsewhere; public exploit on any tier | 30 days | Asset owner's manager |
| **P4 Standard** | Everything else at severity Medium and above | 90 days | Monthly report |

| Priority | Criteria (any) | Due | Escalation if missed |
|---|---|---|---|
| **Informational** | Low severity, informational QIDs, potential-only detections | Next build refresh | None |

> **WHY · WHY THE CLOCK STARTS AT FIRST DETECTION**
> The SLA clock starts when either scanner first detects the finding on that asset, not when a ticket is raised. Starting the clock at ticket creation hides triage backlog and makes MTTR look better than the exposure really was.

## 3.2 Remediation types

Patching is one of four ways to close a finding. Choose the one that removes the exposure fastest with the least risk.

| Type | When | Example |
|---|---|---|
| **Patch / update** | Vendor fix exists | Monthly cumulative update; browser auto-update; vendor hotfix |
| **Configuration change** | The weakness is a setting, not a code flaw | Disable SMBv1; enforce TLS 1.2; remove a weak cipher suite; enable LSA protection |
| **Uninstall / upgrade** | Software is unused, end-of-life or superseded | Remove Java 8 runtimes nobody uses; replace an EOL PDF reader |
| **Compensating control** | No fix, or the system cannot change (validated, vendor-locked) | Network segmentation, application control, disabling the vulnerable service; always with an exception record |

CHAPTER 4

# Method A · Working the Queue in the Consoles

## 4.1 Qualys VMDR

**STEP 1** **Build the weekly prioritized view in Qualys**

1. Sign in to the Qualys platform › `VMDR` › `Vulnerabilities`. Group by `Vulnerability` so one row is one QID across all affected assets.
2. Apply the query for P1 candidates (below). Save it as a **saved search** named `P1 - KEV and exploited`.
3. Add the columns **QDS**, **TruRisk score**, **asset tags** and **first found**. Sort by QDS descending.
4. For each QID, open `Detection` details: confirm the *Results* section shows the evidence (file version, registry key, package version), not just a banner match.
5. Export the view (CSV) or push it to the ticketing integration; one ticket per remediation action, not one per QID per host.

VMDR QUERIES (QQL) · EXAMPLES — QQL

```
# Active, confirmed, high-severity findings on Tier 0 and Tier 1 assets
vulnerabilities.vulnerability.severity:[4..5] and vulnerabilities.typeDetected:Confirmed
  and tags.name:["Tier 0","Tier 1"]

# Findings listed in the CISA Known Exploited Vulnerabilities catalog
vulnerabilities.vulnerability.threatIntel.cisaKnownExploitedVulns:true

# Findings older than 30 days on internet-facing assets
vulnerabilities.firstFound < now-30d and tags.name:"Internet-Facing"
```

**NOTE · CHECK FIELD NAMES IN YOUR SUBSCRIPTION**

QQL tokens are offered by the query builder as you type. Use the builder to confirm token names before saving a search; the examples above show the shape of the queries, not a guaranteed syntax for every VMDR version.

## 4.2 Microsoft Defender Vulnerability Management

**STEP 2** **Review exposure and recommendations in Defender**

1. Open the Microsoft Defender portal › `Endpoints` › `Vulnerability management` › `Dashboard`. Note the **exposure score** and the top security recommendations.

2. Go to `Recommendations`. Filter `Threats` › *Exploit available* and *Active alert / threat*. Sort by **Exposed devices** and **Impact**.
3. Open a recommendation › `Exposed devices`. Confirm device tags and device value; filter to one tier at a time.
4. Select `Request remediation`: choose the remediation type (*Software update*, *Software uninstall* or *Attention required*), due date from the SLA table, priority, and tick `Open a ticket in Intune`.
5. The request appears in `Remediation` › `Activities` and as a **security task** in Intune (`Endpoint security` › `Security tasks`) for the endpoint team to accept.

**STEP 3** **Track software and end-of-support exposure**

1. `Vulnerability management` › `Inventories` › `Software`: filter *End of support = Yes*. Each row shows installed devices and weaknesses.
2. For software no one needs, raise a removal request with the owning team; for software that must stay, schedule the upgrade.
3. `Weaknesses` lists every CVE in the estate with *Exploit available* and *Exposed devices* columns. Use it to answer "are we affected by CVE-X?" within minutes of a disclosure.

> **GOOD PRACTICE · ANSWER "ARE WE EXPOSED?" FROM DEFENDER FIRST**
> When a high-profile CVE is announced, search it in `Weaknesses` and in Qualys `Vulnerabilities` at the same time. Defender usually shows the endpoint answer immediately from existing inventory; Qualys covers servers and network devices once the new QID is released and the agents have reported.

## 4.3 Ticketing: one action, one ticket

Group findings by the action that fixes them. One October cumulative update closes dozens of CVEs on thousands of devices; that is one change, deployed through rings, not thousands of tickets. A ticket records: the action, the asset group, the findings it closes (QIDs / CVEs), the priority and due date, the change reference, and the verification evidence when closed.

CHAPTER 5

# Method B · Hunting, Automation and Verification

## 5.1 Advanced hunting queries

Defender stores vulnerability data in advanced hunting tables, refreshed regularly. These queries turn the console views into reproducible, exportable evidence.

EXPLOITABLE, HIGH-SEVERITY CVES PER DEVICE (DEFENDER) KQL

```
DeviceTvmSoftwareVulnerabilities
| join kind=inner (DeviceTvmSoftwareVulnerabilitiesKB
    | project CveId, CvssScore, IsExploitAvailable, PublishedDate) on CveId
| where VulnerabilitySeverityLevel in ("Critical","High") and IsExploitAvailable == 1
| summarize CVEs = dcount(CveId), TopCVSS = max(CvssScore),
            Software = make_set(SoftwareName, 10) by DeviceName, OSPlatform
| order by CVEs desc
```

WHERE IS THE VULNERABLE VERSION INSTALLED? (SINGLE CVE TRIAGE) KQL

```
let cve = "CVE-2024-XXXXX";
DeviceTvmSoftwareVulnerabilities
| where CveId == cve
| join kind=leftouter (DeviceInfo
    | summarize arg_max(Timestamp, MachineGroup, DeviceCategory) by DeviceId) on DeviceId
| project DeviceName, OSPlatform, SoftwareVendor, SoftwareName, SoftwareVersion,
          RecommendedSecurityUpdate, MachineGroup
```

MISSING SECURITY UPDATES BY KB, FOR PATCH PLANNING KQL

```
DeviceTvmSoftwareVulnerabilities
| where isnotempty(RecommendedSecurityUpdate)
| summarize Devices = dcount(DeviceId), CVEs = dcount(CveId) by RecommendedSecurityUpdate
| order by Devices desc
| take 25
```

**WATCH OUT · REPLACE THE CVE PLACEHOLDER**

`CVE-2024-XXXXX` is a placeholder. Hunting tables refresh on a schedule, not in real time: after a fix is deployed, allow the sensor to report and the tables to refresh before treating a query result as verification.

## 5.2 Deploying fixes

Endpoints are patched through Intune: Windows quality updates through update rings and expedited quality updates for P1 findings (SOP-EM-005), third-party applications through Win32 apps or the Enterprise App Management catalog, and removals through uninstall assignments. Servers outside Intune are patched in maintenance windows with the server patching tool of record. PowerShell fills the gaps: checking state before and after, and remediating one-off configuration findings.

IS THE REQUIRED KB INSTALLED? (FLEET CHECK BEFORE AND AFTER) POWERSHELL

```powershell
$kb = "KB5044284"                                # example: the KB named in the recommendation
$computers = Get-Content .\tier1-servers.txt
$results = Invoke-Command -ComputerName $computers -ThrottleLimit 32 -ErrorAction SilentlyContinue -ScriptBlock
{
    param($kb)
    $os = Get-CimInstance Win32_OperatingSystem
    [pscustomobject]@{
        Computer      = $env:COMPUTERNAME
        Build         = "$($os.Version).$((Get-ItemProperty 'HKLM:\SOFTWARE\Microsoft\Windows
NT\CurrentVersion').UBR)"
        HasKB         = [bool](Get-HotFix -Id $kb -ErrorAction SilentlyContinue)
        LastBoot      = $os.LastBootUpTime
        RebootPending = Test-Path 'HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\WindowsUpdate\Auto
Update\RebootRequired'
    }
} -ArgumentList $kb
$results | Sort-Object HasKB, Computer | Export-Csv ".\kb-check-$(Get-Date -f yyyyMMdd).csv" -NoTypeInformation
$results | Group-Object HasKB | Select-Object Name, Count
```

**NOTE · CUMULATIVE UPDATES AND GET-HOTFIX**

On current Windows releases the monthly cumulative update supersedes earlier ones, so the build number ( `Version.UBR` ) is the more reliable signal. A device on a later build is patched even if `Get-HotFix` does not list the older KB.

THIRD-PARTY APPLICATION: UPGRADE WITH WINGET (RUN AS SYSTEM VIA INTUNE REMEDIATION) POWERSHELL

```powershell
# Detection script: exit 1 if the installed version is below the fixed version
$fixed = [version]"124.0.6367.60"                # example fixed version from the advisory
$app = Get-ItemProperty 'HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Uninstall\*',
                        'HKLM:\SOFTWARE\WOW6432Node\Microsoft\Windows\CurrentVersion\Uninstall\*' |
       Where-Object DisplayName -like 'Google Chrome*' | Select-Object -First 1
if ($app -and [version]$app.DisplayVersion -lt $fixed) { exit 1 } else { exit 0 }

# Remediation script
$winget = Resolve-Path
"$env:ProgramFiles\WindowsApps\Microsoft.DesktopAppInstaller_*_x64__8wekyb3d8bbwe\winget.exe" |
          Select-Object -Last 1
& $winget upgrade --id Google.Chrome --silent --accept-package-agreements --accept-source-agreements --scope
machine
```

CONFIGURATION FINDING: DISABLE SMBV1 SERVER AND VERIFY POWERSHELL

```powershell
Get-SmbServerConfiguration | Select-Object EnableSMB1Protocol
Set-SmbServerConfiguration -EnableSMB1Protocol $false -Force
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol -NoRestart
```

## 5.3 Linux servers

Qualys Cloud Agent and Defender for Endpoint on Linux both report package versions. Remediation follows the distribution's package manager inside the server team's maintenance window:

SECURITY UPDATES ONLY, THEN CONFIRM BASH

```
# Debian / Ubuntu
sudo apt-get update && sudo apt-get install --only-upgrade <package>
apt list --upgradable 2>/dev/null | grep -i security

# RHEL / Rocky / Alma
sudo dnf updateinfo list --security
sudo dnf upgrade --security -y
sudo needs-restarting -r      # exit 1 means a reboot is required
```

## 5.4 Verification and closure

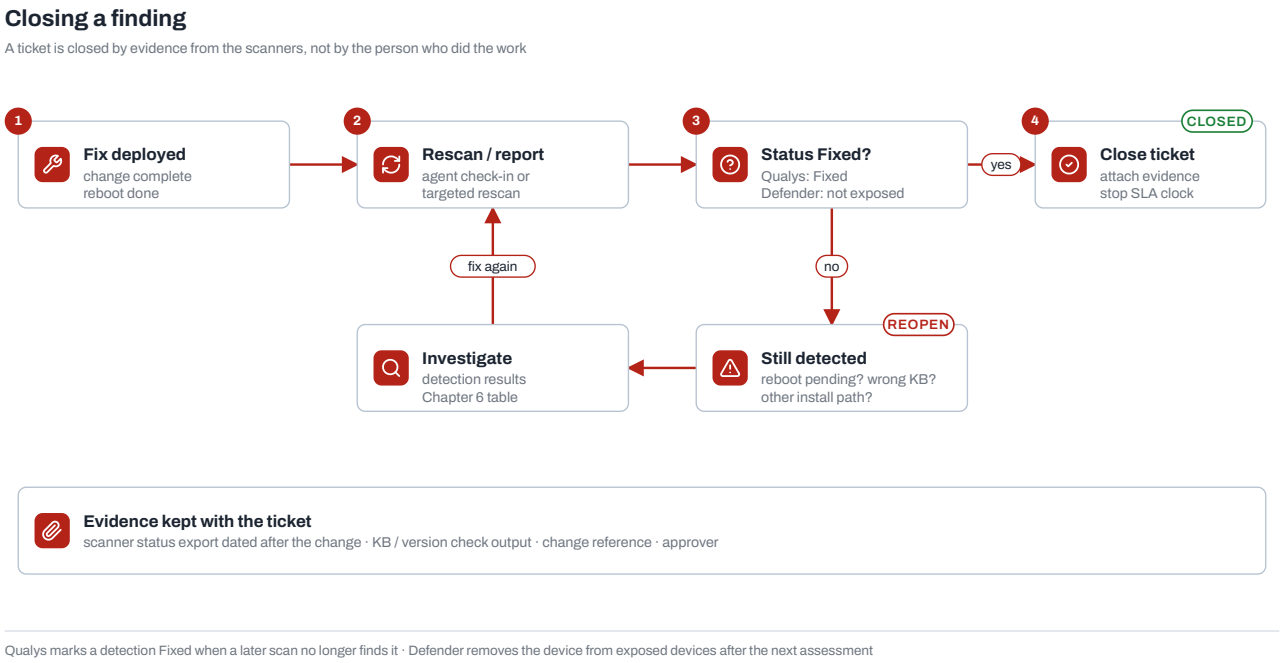



**Figure 4.** Verification. The SLA clock stops when the scanner reports the finding fixed, and the evidence is attached to the ticket.

CHAPTER 6

# Exceptions, Metrics and Reporting

## 6.1 Exception (risk acceptance) workflow

Some findings cannot be fixed inside the SLA: the vendor has no patch, the system is validated and change control takes longer, or the fix breaks a business application. These are not ignored; they become **exceptions** with an owner, a reason, a compensating control and an expiry date. An exception without an expiry is a permanent acceptance nobody signed.

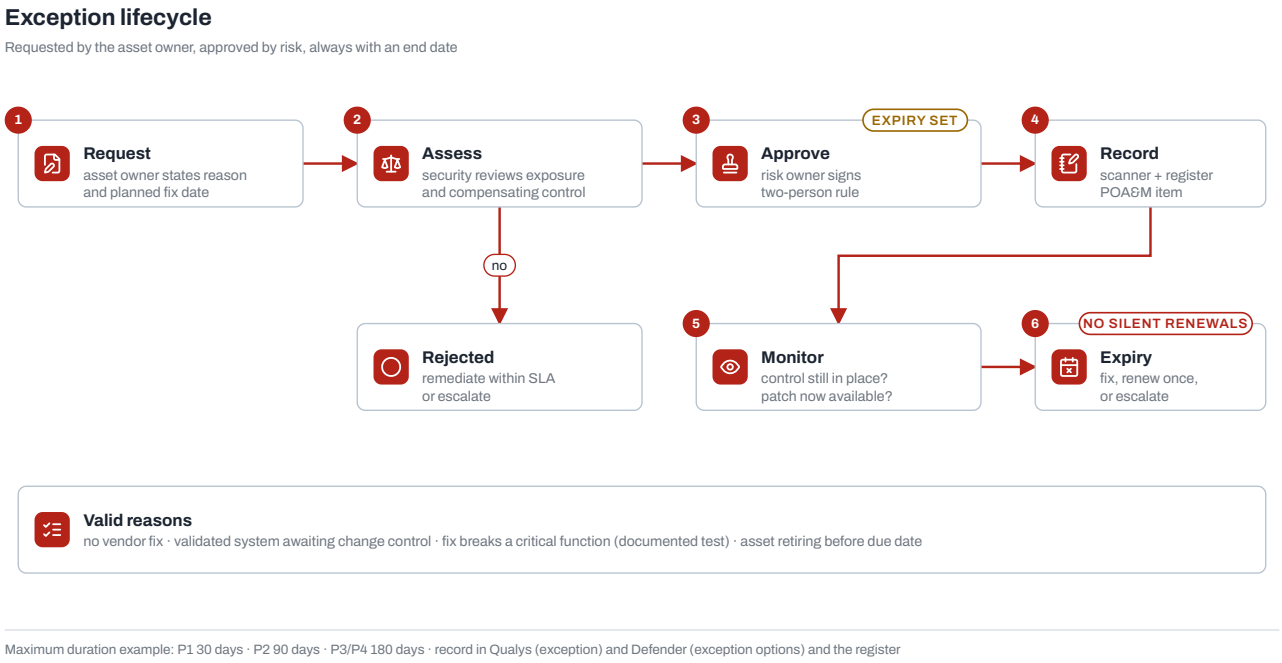



**Figure 5.** Exceptions are time-boxed decisions. In Defender they are created from the recommendation (*Exception options*) with a justification and expiry.

| Defender justification | Use when |
|---|---|
| **Third party control** | Another product mitigates the weakness (for example a WAF in front of a web server). |
| **Alternate mitigation** | A configuration or network control reduces the exposure. |
| **Risk accepted** | The business accepts the risk for a defined period. |
| **Planned remediation (grace)** | A fix is scheduled; keeps the item visible without counting against exposure. |

## 6.2 Metrics that matter

| Metric | Definition | Example target |
|---|---|---|
| **Scan coverage** | Assets with a successful agent check-in or authenticated scan in the last 7 days ÷ assets in inventory | >= 95 % |
| **SLA compliance** | Findings closed within SLA ÷ findings due in the period, by priority | P1 100 % · P2 >= 95 % · P3 >= 90 % |
| **Mean time to remediate (MTTR)** | Average days from first detection to verified fix, by priority | P1 <= 7 d · P2 <= 15 d |
| **Open past due** | Count and age of findings past their due date, by owner | Trending to zero |
| **KEV exposure** | Open KEV findings, by tier | 0 on Tier 0 / internet-facing |
| **Exceptions** | Active exceptions; expiring in 30 days; expired | No expired exceptions |
| **Exposure score** | Defender exposure score trend | Downward month on month |

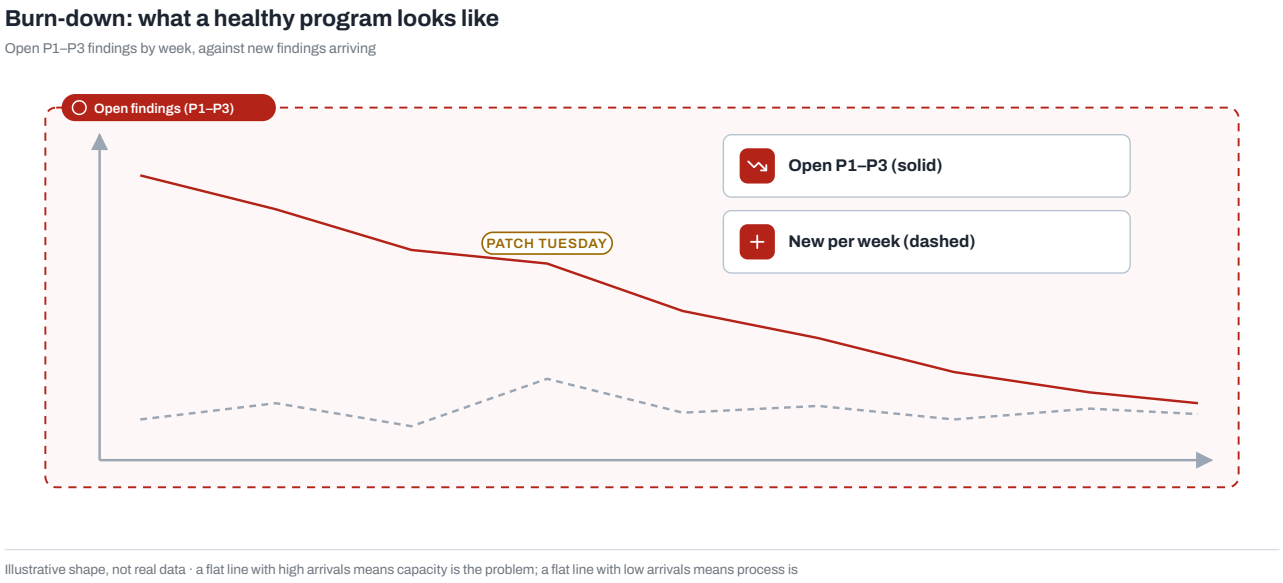



**Figure 6.** Burn-down. Report it weekly to operations and monthly to the risk committee alongside SLA compliance and exceptions.

## 6.3 Reporting cadence

| Audience | Cadence | Content |
|---|---|---|
| **Asset owners** | Weekly | Their open findings, due dates, past due, tickets awaiting action |
| **IT operations leadership** | Weekly | SLA compliance, past due by team, P1 status, burn-down |

| Audience | Cadence | Content |
|---|---|---|
| **Risk committee / CISO** | Monthly | Exposure trend, KEV status, MTTR, exceptions and expiries, coverage gaps |
| **Audit** | On request + quarterly | Policy, scan schedules, evidence samples, exception register, POA&M |

CHAPTER 7

# Verification, Rollback and Troubleshooting

## 7.1 Program health checklist

| Check | How | Expected |
|---|---|---|
| **Coverage** | Qualys agent last check-in + Defender device health vs. CMDB | >= 95 % of in-scope assets reporting in 7 days |
| **Authenticated scans succeed** | Qualys scan results › authentication status | Pass for every target; failures ticketed |
| **Every open finding has an owner and due date** | Queue export | No blanks |
| **P1 findings** | Saved search + hunting query | Zero past due |
| **Exceptions** | Register | All have expiry, approver, compensating control |
| **Evidence** | Sample 5 closed tickets | Each has a post-fix scanner status and change reference |

## 7.2 Rollback

A patch rollback is a change of its own: record it, and reopen the findings it had closed. Pause the ring or assignment first so the update stops spreading, then uninstall where the vendor supports it.

| Situation | Action |
|---|---|
| **Windows quality update breaks an application** | Pause the update ring in Intune; uninstall with `wusa /uninstall /kb:<number> /quiet /norestart` on affected devices; raise an exception for the CVEs until a fixed update is available. |
| **Third-party app upgrade breaks a workflow** | Unassign the remediation; redeploy the previous Win32 package to the affected group; record an exception with a short expiry. |
| **Configuration hardening breaks a dependency** | Revert the single setting (for example re-enable a protocol for one host only); document the dependency and plan its replacement. |
| **Linux package regression** | `dnf history undo <id>` or `apt-get install <package>=<version>`; pin until a fixed build is released. |

## 7.3 Troubleshooting

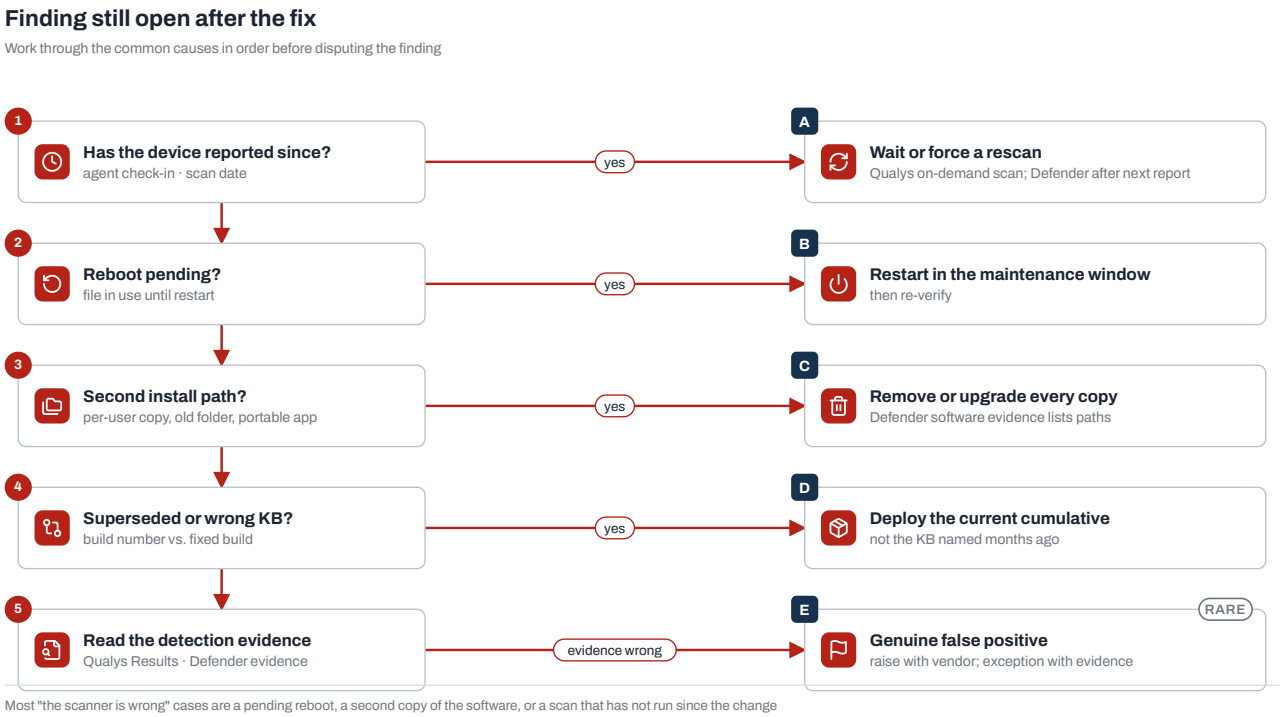



**Figure 7.** Troubleshooting a finding that stays open. Each "yes" has a standard fix; disputes go to the vendor only after step 5.

| Symptom | Likely cause | Fix |
|---|---|---|
| **Authenticated scan shows *Insufficient privileges* or very few findings** | Scan account not local admin, remote registry stopped, or credentials expired | Check the authentication record; confirm GPO grants admin; test with a single host scan. |
| **Same CVE counted twice in reports** | Qualys and Defender both report the device | Reconcile on CVE + device (Chapter 1); report from the merged queue. |
| **Defender shows device as exposed, Qualys says fixed** | Defender inventory not yet refreshed, or a second install path | Check software evidence paths; wait for next assessment; re-query hunting table. |
| **Agent reports, but no vulnerability data** | Agent configuration profile lacks the VM module, or agent not activated for VM | Enable the module in the activation key / configuration profile. |
| **Patched device reappears with the same finding next month** | Image or golden template is outdated | Update the build image and task sequence; track as a finding on the image itself. |
| **Thousands of Medium findings swamp the queue** | Prioritization not applied; owners see raw scanner output | Publish only prioritized views to owners; bulk-fix through monthly cycles. |

CHAPTER 8

# Summary, Glossary and Review

## 8.1 Chapter summary

- A vulnerability program turns scanner findings into a prioritized, owned, dated work queue.
- Every asset needs an owner, a tier and an exposure flag before findings can be prioritized.
- Qualys VMDR and Defender Vulnerability Management are reconciled on CVE and device into one queue.
- Priority starts with exploitation (KEV, active threats, EPSS), then exposure and tier, then CVSS.
- Fix by the action that closes the most risk: patch, configuration change, removal or compensating control.
- A finding is closed by a rescan, not by a ticket; evidence is attached.
- Exceptions are time-boxed, approved and reviewed; metrics are coverage, SLA compliance, MTTR, past due and KEV exposure.

**Check your understanding**

1. Why does the SLA clock start at first detection rather than at ticket creation?
2. A CVE has CVSS 9.8 but no known exploitation and sits on a Tier 3 laptop; another has CVSS 6.5, is on CISA KEV and sits on a VPN gateway. Which is fixed first, and by when, under the example policy?
3. What is the difference between a QID and a CVE, and how does it affect reconciliation?
4. A server still shows the finding after the KB was installed. List three causes to check before calling it a false positive.
5. What four things must every exception record contain?

## 8.2 Glossary

| | |
|---|---|
| **VMDR** | Qualys Vulnerability Management, Detection and Response. |
| **QID** | Qualys ID: identifier of a Qualys detection check; may map to one or more CVEs. |
| **QDS / TruRisk** | Qualys Detection Score (1–100) for a finding, and TruRisk score for an asset combining findings and asset criticality. |
| **MDVM** | Microsoft Defender Vulnerability Management, built on the Defender for Endpoint sensor. |
| **Exposure score** | Defender score (0–100) reflecting how exposed the organization's devices are to known vulnerabilities. |
| **CISA KEV** | Known Exploited Vulnerabilities catalog maintained by CISA under BOD 22-01. |

| | |
|---|---|
| **EPSS** | Exploit Prediction Scoring System: probability a CVE will see exploitation activity in the next 30 days. |
| **MTTR** | Mean time to remediate: average days from first detection to verified fix. |
| **POA&M** | Plan of Action and Milestones: tracked list of known weaknesses with planned remediation dates. |
| **Compensating control** | Alternative safeguard that reduces risk when the primary fix cannot be applied. |

## 8.3 Framework references

| Framework | Controls addressed |
|---|---|
| **NIST SP 800-53 Rev. 5** | RA-5 Vulnerability Monitoring and Scanning · RA-5(5) privileged access · SI-2 Flaw Remediation · SI-2(2) automated status · CA-5 Plan of Action and Milestones · CM-8 System Component Inventory · RA-3 Risk Assessment |
| **CIS Controls v8** | Control 7 Continuous Vulnerability Management (7.1–7.7) · Control 1 Inventory of Enterprise Assets · Control 2 Inventory of Software Assets |
| **CISA BOD 22-01** | Remediation of known exploited vulnerabilities by catalog due dates |
| **FDA 21 CFR Part 11 / GxP** | Patches to validated systems follow change control and documented impact assessment (SOP-GOV-001) |